

Web Quality & Security Audit Report

An automated, evidence-based assessment of your site's public-facing security posture, performance budget, accessibility compliance, and search-engine readiness.

nike.com

Unauthenticated scope · public surface · 1 origin

**REPORT DATE****May 18, 2026****SCAN DURATION****60s****FINDINGS****50 issues · 0 passed****SCANNER****VibeSafe v0.4.2****CONTENTS**

Executive summary

02

Scope & methodology

03

Priority findings	04	Recommended next steps	08
All findings	05	Glossary & references	09
What passed	06	Report attestation	10
Compliance signals	07		

Prepared for
rahulsunny13@gmail.com

Report ID
rpt_cmpayk59

Confidentiality Internal
use

01 Executive summary

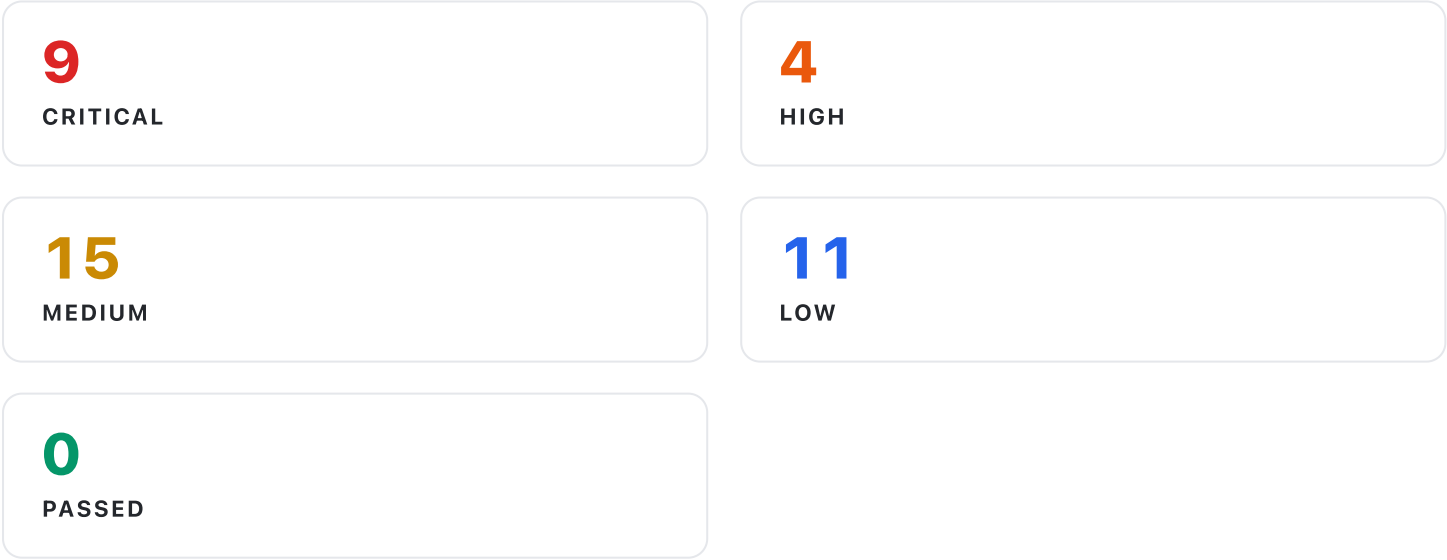
nike.com earned an overall grade of **F (321/100)**. 9 critical issues need immediate attention. 41 other findings reduce defense-in-depth.



Critical action required

This site has security gaps that put user data and trust at risk. Address the priority findings before anything else; many are single-line header changes or config tweaks. Closing the priority findings would lift this to a projected **D**.

FINDINGS BY SEVERITY



SCORE BY CATEGORY

 Security	321 / 100
 Performance	43 / 100
 Accessibility	92 / 100
 SEO	100 / 100

What this report covers and what it doesn't. VibeSafe tested only what an anonymous visitor can reach: the public, unauthenticated surface of nike.com. Authenticated routes, admin flows, and post-login state weren't probed. Source code, dependency SBOMs, and live exploit verification are out of scope for a passive scan — see *Recommended next steps*.

02 Scope & methodology

This scan executed 21 detection modules across security, performance, accessibility, and SEO. Every finding below is backed by reproducible evidence captured at scan time.

Target URL https://nike.com

Detected stack React

Modules run 21 of 21

Authentication None — anonymous visitor only

Scan duration 60s

Scanner version VibeSafe v0.4.2

WHAT WE TESTED

- Exposed API keys & secrets
Source code leak check
Browser security defenses
HTTPS / SSL setup
Cookie & session safety
Hidden admin & config files
Cross-origin access rules
Insecure resource loading
External script safety
Email spoofing protection
Dormant subdomain check
- Leaky error messages
Exposed admin pages
Search engine exposure
Cache leak check
Cookie consent banner check
Privacy policy presence
Data-protection header signals
Accessibility compliance claim
Third-party data exposure
User rights & opt-out signals

Reproducibility. Each finding's *Evidence* block contains the raw request/response excerpt that triggered the detection. Module IDs (e.g. P1-01) map to the source files in `src/lib/scanner/modules/`.

03 Priority findings

Page 04

These 5 findings move the most points on your grade. We recommend fixing them first; the rest can be batched with normal maintenance.

CRITICAL 1. Sensitive file publicly accessible: /.env

P1-06

 Sensitive Path Exposure  /.env

The file /.env is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env → HTTP 403
```

REMEDIATION

Block access to /.env immediately via your hosting platform or CDN.
Audit the file for any credentials and rotate them immediately.
Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.
Verify the fix: the path should return 404, not 403.

CRITICAL 2. Sensitive file publicly accessible: /.env.local

P1-06

 Sensitive Path Exposure  /.env.local

The file /.env.local is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.local → HTTP 403
```

REMEDIATION

Block access to /.env.local immediately via your hosting platform or CDN.
Audit the file for any credentials and rotate them immediately.
Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.
Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.production

The file /.env.production is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.production → HTTP 403
```

REMEDIATION

Block access to /.env.production immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.backup

The file /.env.backup is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.backup → HTTP 403
```

REMEDIATION

Block access to /.env.backup immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/index

The file /.git/index is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/index → HTTP 403
```

REMEDIATION

Block access to /.git/index immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

04 All findings

Page 05+

50 findings, grouped by category and ordered by severity within each.

SENSITIVE PATH EXPOSURE · 11 ISSUES

CRITICAL Sensitive file publicly accessible: /.env

P1-06

 Sensitive Path Exposure  /.env

The file /.env is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

GET /.env → HTTP 403

REMEDIATION

- Block access to /.env immediately via your hosting platform or CDN.
- Audit the file for any credentials and rotate them immediately.
- Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.
- Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.local

The file /.env.local is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.local → HTTP 403
```

REMEDIATION

Block access to /.env.local immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.production

The file /.env.production is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.production → HTTP 403
```

REMEDIATION

Block access to /.env.production immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.backup

The file /.env.backup is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.backup → HTTP 403
```

REMEDIATION

Block access to /.env.backup immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.git/index

The file /.git/index is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.git/index → HTTP 403
```

REMEDIATION

Block access to /.git/index immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.hg/store

The file /.hg/store is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.hg/store → HTTP 403
```

REMEDIATION

Block access to /.hg/store immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /index.php.bak

The file /index.php.bak is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /index.php.bak → HTTP 403
```

REMEDIATION

Block access to /index.php.bak immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.bak

The file /.env.bak is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.bak → HTTP 403
```

REMEDIATION

Block access to /.env.bak immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

 Sensitive Path Exposure  /.env.old

The file /.env.old is publicly accessible. This type of file commonly contains secrets, credentials, or database contents that should never be exposed.

IMPACT

Depending on file contents: full credential exposure, database access, or complete source code leak.

EVIDENCE

```
GET /.env.old → HTTP 403
```

REMEDIATION

Block access to /.env.old immediately via your hosting platform or CDN.

Audit the file for any credentials and rotate them immediately.

Add the path to your deny-list in vercel.json, nginx.conf, or equivalent.

Verify the fix: the path should return 404, not 403.

HIGH 8 sensitive paths returned non-404 responses

P1-06

Sensitive Path Exposure

 /actuator/health, /actuator/env, /package.json, /composer.json, /Pipfile, /CVS/Entries, /.DS_Store, /Thumbs.db

Several paths that are typically hidden or admin-only returned non-404 status codes, indicating they may be accessible or discoverable.

IMPACT

Admin panels, API docs, or debug interfaces may be accessible to unauthenticated users.

EVIDENCE

/actuator/health (HTTP 403), /actuator/env (HTTP 403), /package.json (HTTP 403), /composer.json (HTTP 403), /Pipfile (HTTP 403), /CVS/Entries (HTTP 403), /.DS_Store (HTTP 403), /Thumbs.db (HTTP 403)

REMEDIATION

Review each flagged path and determine whether it should be publicly accessible.

Add authentication to any admin or debug interfaces.

Return 404 (not 403) for paths that should not exist — 403 confirms the path exists.

MEDIUM 3 dependency-lock files publicly accessible

P1-06

Sensitive Path Exposure /yarn.lock, /package-lock.json, /Gemfile.lock

Dependency-lock files (yarn.lock, package-lock.json, Gemfile.lock) do not contain secrets, but they make the exact version of every dependency public. Combined with our client-side dependency CVE matching (P1-16), this gives an attacker a precise list of known-vulnerable libraries to target.

IMPACT

Version pinning becomes public, narrowing the attacker's search space for known CVEs in your stack. No direct credential exposure.

EVIDENCE

/yarn.lock (HTTP 403), /package-lock.json (HTTP 403), /Gemfile.lock (HTTP 403)

REMEDIATION

Block lockfiles at the edge in vercel.json, next.config.js headers(), or your nginx/CDN config.

Verify by re-fetching the path: it should return 404, not 200.

Lockfiles still belong in your repo; only the deployed site should not serve them.

HIGH Largest Contentful Paint (LCP) is too slow

P2-01

 Performance  Core Web Vitals

LCP measures how long it takes for the largest element on your page (usually a hero image, heading, or text block) to become visible. Slow LCP directly impacts user experience and Google search rankings. Users are likely to abandon slow-loading pages.

IMPACT

Poor LCP correlates with 20-40% higher bounce rates and lower conversion rates. Google uses LCP as a ranking signal — slow pages rank lower in search results.

EVIDENCE

LCP: 10.30s (target: < 2.0s for GOOD)

REMEDIATION

Optimize your largest image: convert to WebP/AVIF, compress, use responsive images with srcset

Eliminate render-blocking CSS and JavaScript: inline critical CSS, defer non-critical JS

Use a CDN to serve static assets closer to users

Enable server-side rendering (SSR) or static generation for faster initial HTML

MEDIUM First Contentful Paint (FCP) is too slow

P2-01

 Performance  Core Web Vitals

FCP measures how long it takes for ANY content (text, image, SVG) to appear on screen. Slow FCP makes users think your site is broken or unresponsive.

IMPACT

Users may abandon your site before seeing any content. First impressions matter — slow FCP damages perceived performance.

EVIDENCE

FCP: 3.70s (target: < 1.5s for GOOD)

REMEDIATION

Reduce server response time (optimize backend, use edge caching)

Eliminate render-blocking JavaScript and CSS

Inline critical CSS in the <head>

Use server-side rendering or static generation

MEDIUM

Total Blocking Time (TBT) is too high

P2-01

 Performance  Core Web Vitals

TBT measures how long the main thread is blocked by long tasks during page load. High TBT means your page feels sluggish and unresponsive — buttons don't click immediately, inputs don't respond.

IMPACT

Users experience delays when interacting with your page. This is a strong proxy for Interaction to Next Paint (INP), which replaces FID in 2026.

EVIDENCE

TBT: 918ms (target: < 200ms for GOOD)

REMEDIATION

- Break up long JavaScript tasks (use code splitting, lazy loading)
- Remove or defer non-critical third-party scripts
- Use web workers for CPU-intensive operations
- Optimize JavaScript execution time (reduce complexity, avoid blocking work)

MEDIUM

Reduce unused JavaScript

P2-02

 Performance  Resource Optimization

Your JavaScript bundles contain code that is never executed on this page. Unused code increases download time, parse time, and compile time — slowing down the entire page load.

IMPACT

Potential savings: 650 KB. Reducing unused JS improves FCP, LCP, and TBT by reducing parse/compile time.

EVIDENCE

650 KB of unused JavaScript detected

REMEDIATION

- Implement code splitting: use dynamic imports for routes and features
- Remove unused npm packages and dead code
- Use tree-shaking (ensure ES6 modules, not CommonJS)
- Lazy load non-critical features (modals, charts, heavy components)

 Performance  JavaScript Performance

Your JavaScript is blocking the main thread for too long. Long-running JavaScript tasks prevent the browser from responding to user interactions like clicks, taps, and keyboard input. This makes your site feel sluggish and unresponsive.

IMPACT

Users experience delays when clicking buttons, typing in forms, or scrolling. This directly impacts Interaction to Next Paint (INP), which is replacing First Input Delay as a Core Web Vital in 2026.

EVIDENCE

Total Blocking Time: 918ms (target: < 200ms)

REMEDIATION

- Break up long JavaScript tasks: split synchronous work into smaller chunks
- Use code splitting to load JavaScript on-demand (React.lazy, dynamic imports)
- Defer non-critical JavaScript with async or defer attributes
- Move CPU-intensive work to Web Workers (parsing, computation, data processing)

 Performance  JavaScript Performance

Time to Interactive measures how long it takes before your page is fully usable — all content loaded, event handlers registered, and page responds to user input within 50ms. Slow TTI means users see content but can't interact with it yet.

IMPACT

Users may click buttons that don't work yet, leading to frustration. This is especially problematic on mobile devices with slower CPUs.

EVIDENCE

TTI: 20.1s (target: < 3.8s for mobile)

REMEDIATION

- Reduce JavaScript execution time (minimize, compress, code split)
- Eliminate render-blocking scripts in <head>
- Defer third-party scripts (analytics, chat widgets, ads) until after page load
- Use server-side rendering or static generation to reduce client-side work

LOW

Speed Index indicates slow visual progress

P2-04

 Performance  JavaScript Performance

Speed Index measures how quickly content is visually populated during page load. A high Speed Index means content appears slowly, making users wait to see meaningful information.

IMPACT

Users perceive your site as slow even if technical metrics like TTFB are good. Visual progress matters for user experience.

EVIDENCE

Speed Index: 4.9s (target: < 3.4s for mobile)

REMEDIATION

- Prioritize above-the-fold content (inline critical CSS, preload hero images)
- Remove render-blocking JavaScript
- Use skeleton screens or loading placeholders for better perceived performance
- Optimize web fonts: use font-display: swap and preload fonts

LOW

Viewport prevents user scaling (accessibility issue)

P2-06

 Performance  Mobile Performance

Your viewport meta tag prevents users from zooming in. This is an accessibility violation — users with visual impairments need to be able to zoom to read content.

IMPACT

Violates WCAG 2.1 accessibility guidelines. Users cannot enlarge text for readability.

EVIDENCE

Viewport meta tag: width=device-width, initial-scale=1, maximum-scale=1

REMEDIATION

- Remove user-scalable=no from viewport tag
- Remove maximum-scale=1 restriction
- Use: <meta name="viewport" content="width=device-width, initial-scale=1">
- Allow users to zoom up to at least 200% (WCAG requirement)

 Performance  Core Web Vitals (Transparency)

Largest Contentful Paint is in the Poor band (≥ 4.0 s). Even if the overall Lighthouse score is moderate due to other metrics passing, this individual metric is in the worst category and directly affects user experience.

IMPACT

LCP in the Poor band signals users are waiting a long time for the page to look usable. Google uses LCP as a primary Core Web Vitals ranking factor.

EVIDENCE

LCP: 10.30s – Poor threshold: ≥ 4.0 s

REMEDIATION

See the Largest Contentful Paint finding above for detailed fix guidance

 Performance  Core Web Vitals (Transparency)

First Contentful Paint is in the Poor band (≥ 3.0 s). Users see no content at all for over 3 seconds, which causes high abandonment.

IMPACT

Poor FCP creates a perception of a broken or unresponsive page before any content appears.

EVIDENCE

FCP: 3.70s – Poor threshold: ≥ 3.0 s

REMEDIATION

See the First Contentful Paint finding above for detailed fix guidance

 Performance  Core Web Vitals (Transparency)

Total Blocking Time is in the Poor band ($\geq 600\text{ms}$). The main thread is heavily blocked, making the page feel unresponsive for an extended period. This is a strong predictor of a poor INP score.

IMPACT

Poor TBT means users experience significant input delay during page load. INP (the 2026 CWV replacement for FID) will be directly harmed.

EVIDENCE

TBT: 918ms – Poor threshold: $\geq 600\text{ms}$

REMEDIATION

See the Total Blocking Time finding above for detailed fix guidance

 Performance  Real-User Field Experience

CrUX field data shows real users rate this page as AVERAGE (needs improvement). The page is not in the SLOW band, but there is room to reach the FAST threshold and improve Core Web Vitals rankings.

IMPACT

Pages rated AVERAGE by CrUX will not receive the "Good" Core Web Vitals badge in Google Search and may rank below FAST competitors.

EVIDENCE

Overall: AVERAGE | LCP p75=1515ms (FAST) | INP p75=164ms (FAST) | CLS p75=0.000 (FAST) | FCP p75=1172ms (FAST)

REMEDIATION

Review individual metric verdicts to find which CWV is pulling the overall category to AVERAGE
Target the metric closest to the FAST threshold for the highest return on effort

HIGH

Canonical URL resolves to HTTP 403

P4-01



SEO



HTML <head> element

A canonical URL must resolve to a single, stable 2xx page. Loops, redirects to blocked hosts, or non-2xx canonicals leave search engines unable to pick the authoritative URL, splitting or dropping ranking signals.

IMPACT

Search engines may ignore the canonical and index duplicates, or drop the page entirely.

EVIDENCE

<link rel="canonical" href="https://www.nike.in/"> → resolves to HTTP 403 (after 1 hop)

REMEDIATION

Point rel=canonical at the final, self-resolving 2xx URL.

Remove redirect chains on the canonical target.

Use an absolute https URL that returns 200.

MEDIUM

Missing structured data (Schema.org markup)

P4-03



SEO



HTML <head> or <body>

Structured data (Schema.org markup) helps search engines understand your content and can enable rich snippets in search results. Rich snippets include star ratings, breadcrumbs, FAQs, and more, which increase visibility and click-through rates.

IMPACT

Page will not appear with rich snippets in search results. Missing opportunities for enhanced visibility with star ratings, prices, availability, breadcrumbs, and other rich features. Competitors with structured data may appear more prominently.

EVIDENCE

No JSON-LD structured data found

REMEDIATION

Add JSON-LD structured data to your <head> or <body>

Common types to implement:

- Organization: For company info and logo
- WebSite: For site name and search box

 Sourcemap Exposure

🔗 /NIKE/nes-nike-reloaded-svc/static/ui_components.c6acc56a94.js.map, /NIKE/nes-nike-reloaded-svc/static/vendor.crit2.0f98fed245.js.map, /NIKE/nes-nike-reloaded-svc/static/vendor.crit1.207792672d.js.map, /NIKE/nes-nike-reloaded-svc/static/6377.e2815574e9.js.map, /NIKE/nes-nike-reloaded-svc/static/bundle.ed6bdd0952.js.map, /NIKE/nes-nike-reloaded-svc/static/5131.f2bb81274b.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/app.9ed5c64435.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/1942.653879240e.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/5936.4cfd71a55.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/7913.010d78e017.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/boot.765c88b342.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/newRelicBrowser.24a457a635.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/visitor-prioritization.391014fa18.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/8177.f02fe687ba.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/7768.eb8b27d1fd.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/1607.2e50a89f2d.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/8916.d0d527b0d0.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/5335.e33104d5fe.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/5676.1a97b96c6d.chunk.js.map, /NIKE/nes-nike-reloaded-svc/static/8898.378d050156.chunk.js.map

Sourcemap files (.map) map compiled JavaScript back to your original source code. When these are publicly accessible in production, anyone can read your unminified TypeScript/JSX, including business logic, component names, and file structure.

IMPACT

Attackers can read your original source to find additional vulnerabilities, understand authentication flows, and discover internal API endpoints.

EVIDENCE

```
HEAD /NIKE/nes-nike-reloaded-svc/static/ui_components.c6acc56a94.js.map → HTTP 200
```

REMEDIATION

In Next.js, set `productionBrowserSourceMaps: false` in `next.config.js`.
Redeploy after making the change — existing .map files are still cached.
Verify by running: `curl -I <your-bundle-url>.map` (should return 404).

ACCESSIBILITY · 2 ISSUES

 Accessibility  WCAG 1.3.1, 2.4.6 - Headings

Properly ordered headings that do not skip levels convey the semantic structure of the page, making it easier to navigate and understand when using assistive technologies. [Learn more about heading order] (<https://dequeuniversity.com/rules/axe/4.11/heading-order>).

IMPACT

Screen reader users cannot understand page structure. Navigation by headings becomes confusing and inefficient.

EVIDENCE

Heading levels skip (e.g., h1 → h3, missing h2) in 1 location

REMEDIATION

- Start with a single h1 for the main page title
- Use h2 for main sections, h3 for subsections, etc.
- Never skip heading levels (don't jump from h2 to h4)
- It's OK to go back up (h4 → h2) when starting a new section

 Accessibility  WCAG 1.4.4 - Resize Text

Disabling zooming is problematic for users with low vision who rely on screen magnification to properly see the contents of a web page. [Learn more about the viewport meta tag] (<https://dequeuniversity.com/rules/axe/4.11/meta-viewport>).

IMPACT

Users with low vision cannot zoom in to read text on mobile devices.

EVIDENCE

Meta viewport uses `user-scalable=no` or `maximum-scale < 5`

REMEDIATION

- Remove `user-scalable=no` from viewport meta tag
- Remove `maximum-scale` if set to less than 5
- Use: `<meta name="viewport" content="width=device-width, initial-scale=1">`
- Design responsive layouts instead of blocking zoom

 Best Practices  Lighthouse audit: valid-source-maps

Source maps translate minified code to the original source code. This helps developers debug in production. In addition, Lighthouse is able to provide further insights. Consider deploying source maps to take advantage of these benefits. [Learn more about source maps]
(<https://developer.chrome.com/doc...>)

IMPACT

Failing best-practices audits can indicate security issues, browser compatibility problems, deprecated APIs, or development errors that negatively affect user experience and maintainability.

EVIDENCE

score=0.00

REMEDIATION

Review the 'valid-source-maps' Lighthouse audit in your browser DevTools Lighthouse panel for specific failing elements.

Consult the Lighthouse documentation for remediation guidance:
<https://developer.chrome.com/docs/lighthouse/best-practices/>

DATA PROTECTION · 3 ISSUES

 Data Protection  HTTP response headers

Content-Security-Policy (CSP) limits which scripts and resources the browser may load. Without it, an XSS vulnerability could allow a script to read and exfiltrate personal data (form inputs, localStorage, cookies) to an attacker-controlled endpoint. Restricting script execution is a practical technical control for protecting data in transit to the browser.

IMPACT

A successful XSS attack on a page that handles personal data can extract that data silently. CSP materially raises the bar for exfiltration even when an injection point is present.

EVIDENCE

content-security-policy header not present

REMEDIATION

Start with a report-only policy: Content-Security-Policy-Report-Only: default-src 'self'
Review the report endpoint for violations, then tighten and promote to enforcement.
Add specific domain allowlists for analytics, fonts, and third-party scripts.

LOW

Data-protection-relevant header not set: Referrer-Policy

P5-03

 Data Protection  HTTP response headers

Referrer-Policy controls how much of the page URL is included in the Referer header when a user navigates to another site. Without a restrictive policy, the full URL — including any query parameters — is sent to third-party destinations. Query parameters frequently carry personal data such as user IDs, search terms, or email addresses. Data-minimisation principles in frameworks such as GDPR recommend sending only the bare origin when crossing site boundaries.

IMPACT

Personal data embedded in query parameters (user identifiers, tokens, email addresses) may be logged by third-party analytics, ad networks, or embedded widget providers without the user's knowledge.

EVIDENCE

```
referrer-policy header not present
```

REMEDIATION

Add: Referrer-Policy: strict-origin-when-cross-origin

This sends only the origin on cross-origin navigation and the full URL within your own site.

Use no-referrer for maximum privacy if referrer analytics are not required.

LOW

Data-protection-relevant header not set: Permissions-Policy

P5-03

 Data Protection  HTTP response headers

Permissions-Policy restricts whether the browser may grant camera, microphone, geolocation, and payment access to the page and any embedded iframes. Without it, third-party scripts or iframes can request these sensitive capabilities. Limiting access to what the application actually requires is consistent with data-minimisation principles.

IMPACT

A compromised or malicious third-party script embedded on the page could request camera, microphone, or geolocation access without the user realising the source is not the first-party site.

EVIDENCE

```
permissions-policy header not present
```

REMEDIATION

Add: Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()

Adjust the allowlist per feature based on what the application actually uses.

 DNS & Email Security  DNS TXT @ nike.in

SPF (Sender Policy Framework) specifies which mail servers are authorised to send email on behalf of your domain. Without SPF, anyone can send email appearing to come from your domain.

IMPACT

Your domain can be used to send phishing emails to your users and customers. This damages brand trust and can get your domain blacklisted.

EVIDENCE

No v=spf1 record found for nike.in

REMEDIATION

Add a DNS TXT record for nike.in: v=spf1 include:_spf.your-mail-provider.com -all

Replace the include: value with your actual email provider (e.g., include:_spf.google.com for Google Workspace).

Use -all (hard fail) rather than ~all (soft fail) for stricter enforcement.

 DNS & Email Security  DNS TXT @ _dmarc.nike.in

DMARC tells receiving mail servers what to do when an email fails SPF or DKIM checks. Without DMARC, there is no policy for handling spoofed emails.

IMPACT

Even with SPF and DKIM configured, receiving servers have no policy to follow when verification fails — spoofed emails may still reach inboxes.

EVIDENCE

No v=DMARC1 record found for _dmarc.nike.in

REMEDIATION

Add a DNS TXT record for _dmarc.nike.in: v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@nike.in

Start with p=none to monitor (no action), then move to p=quarantine, then p=reject.

The rua= address receives aggregate reports so you can monitor legitimate mail flow.

 Security Headers  HTTP response headers

CSP controls which scripts, styles, and resources the browser is allowed to load. Without it, a single XSS vulnerability can load scripts from any domain and fully compromise user sessions.

IMPACT

If any XSS vulnerability exists (in your code or a third-party script), attackers have no guardrails — they can load external scripts, exfiltrate data, and steal credentials.

EVIDENCE

```
content-security-policy header not present
```

REMEDIATION

Add Content-Security-Policy to your response headers via `next.config.js` or `vercel.json`.

Start with a report-only policy to see what would break: Content-Security-Policy-Report-Only: default-src 'self'

Tighten the policy progressively, adding specific domains as needed.

 Security Headers  HTTP response headers

Without this header, your site can be embedded in an `<iframe>` on a malicious page. Attackers use this for clickjacking — tricking users into clicking buttons they cannot see.

IMPACT

Clickjacking attacks can trick users into submitting forms, changing settings, or performing account actions they did not intend.

EVIDENCE

```
x-frame-options header not present
```

REMEDIATION

Add: X-Frame-Options: SAMEORIGIN

Or use CSP: frame-ancestors 'self' (more modern and flexible).

 Security Headers  Initial HTML `<script src>` tags

Subresource Integrity (SRI) lets the browser verify a fetched script matches a known hash before executing it. Cross-origin scripts loaded without an `integrity` attribute will be executed unconditionally, so a compromise of the CDN, a typosquatted host, or a hostile mirror can silently swap the script for malicious code.

IMPACT

If any of the third-party CDNs serving these scripts is compromised, the swapped script runs with full access to your origin — including session cookies, localStorage, and user input.

EVIDENCE

```
<script src="https://connect.facebook.net/signals/config/351341038378023?
v=2.9.319&r=stable&domain=www.nike.in&hme=7441a59ee5070e08bd0157a62d39bd
95bf3afdcc83dafbad800e78b5416300a9&ex_m=104%2C207%2C155%2C22%2C72%2C73%2C146%2C6
8%2C67%2C11%2C164%2C90%2C16%2C138%2C48%2C147%2C77%2C112%2C47%2C127%2C39%2C75%2C78%2C
134%2C160%2C166%2C8%2C4%2C5%2C7%2C6%2C3%2C91%2C101%2C167%2C172%2C221%2C62%2C188%2C18
9%2C55%2C278%2C30%2C74%2C233%2C232%2C231%2C23%2C33%2C103%2C61%2C10%2C63%2C97%2C98%2C
99%2C105%2C130%2C31%2C29%2C132%2C133%2C129%2C128%2C156%2C76%2C159%2C157%2C158%2C50%2
C60%2C123%2C15%2C163%2C45%2C265%2C266%2C264%2C26%2C27%2C28%2C18%2C20%2C44%2C40%2C42%
2C41%2C83%2C92%2C96%2C110%2C145%2C148%2C46%2C111%2C24%2C21%2C119%2C69%2C36%2C150%2C1
49%2C151%2C142%2C140%2C25%2C35%2C59%2C109%2C162%2C70%2C17%2C153%2C114%2C81%2C66%2C19
%2C85%2C86%2C116%2C84%2C136%2C135%2C139%2C161%2C34%2C280%2C296%2C214%2C203%2C204%2C2
02%2C299%2C290%2C52%2C215%2C107%2C131%2C80%2C121%2C54%2C49%2C113%2C120%2C126%2C58%2C
64%2C152%2C115%2C37%2C32%2C53%2C56%2C100%2C165%2C1%2C124%2C14%2C122%2C12%2C2%2C57%2C
93%2C65%2C118%2C89%2C88%2C168%2C169%2C94%2C95%2C9%2C125%2C102%2C51%2C143%2C87%2C79%2
C71%2C117%2C106%2C43%2C144%2C0%2C82%2C137%2C141%2C154%2C38%2C108%2C13%2C170%2C230%2C
229%2C224%2C226%2C227%2C228%2C225%2C213%2C223%2C195%2C192%2C193%2C187%2C191%2C194%2C
190%2C185%2C320%2C257%2C259%2C260%2C261%2C258%2C262%2C206%2C256%2C198%2C217%2C186%2C
184%2C237%2C208%2C178%2C179%2C174%2C180%2C177%2C175%2C176%2C173%2C171%2C182%2C183%2C
181%2C267%2C319%2C196%2C240%2C241%2C246%2C243%2C245%2C244%2C242%2C239%2C293"> (no
integrity)
<script src="https://connect.facebook.net/signals/config/846743554864928?
v=2.9.319&r=stable&domain=www.nike.in&hme=7441a59ee5070e08bd0157a62d39bd
95bf3afdcc83dafbad800e78b5416300a9&ex_m=104%2C207%2C155%2C22%2C72%2C73%2C146%2C6
8%2C67%2C11%2C164%2C90%2C16%2C138%2C48%2C147%2C77%2C112%2C47%2C127%2C39%2C75%2C78%2C
134%2C160%2C166%2C8%2C4%2C5%2C7%2C6%2C3%2C91%2C101%2C167%2C172%2C221%2C62%2C188%2C18
9%2C55%2C278%2C30%2C74%2C233%2C232%2C231%2C23%2C33%2C103%2C61%2C10%2C63%2C97%2C98%2C
99%2C105%2C130%2C31%2C29%2C132%2C133%2C129%2C128%2C156%2C76%2C159%2C157%2C158%2C50%2
C60%2C123%2C15%2C163%2C45%2C265%2C266%2C264%2C26%2C27%2C28%2C18%2C20%2C44%2C40%2C42%
2C41%2C83%2C92%2C96%2C110%2C145%2C148%2C46%2C111%2C24%2C21%2C119%2C69%2C36%2C150%2C1
49%2C151%2C142%2C140%2C25%2C35%2C59%2C109%2C162%2C70%2C17%2C153%2C114%2C81%2C66%2C19
%2C85%2C86%2C116%2C84%2C136%2C135%2C139%2C161%2C34%2C280%2C296%2C214%2C203%2C204%2C2
02%2C299%2C290%2C52%2C215%2C107%2C131%2C80%2C121%2C54%2C49%2C113%2C120%2C126%2C58%2C
64%2C152%2C115%2C37%2C32%2C53%2C56%2C100%2C165%2C1%2C124%2C14%2C122%2C12%2C2%2C57%2C
93%2C65%2C118%2C89%2C88%2C168%2C169%2C94%2C95%2C9%2C125%2C102%2C51%2C143%2C87%2C79%2
C71%2C117%2C106%2C43%2C144%2C0%2C82%2C137%2C141%2C154%2C38%2C108%2C13%2C170"> (no
integrity)
<script src="https://connect.facebook.net/en_US/fbevents.js"> (no integrity)
<script src="https://www.googletagmanager.com/gtag/js?id=G-
DZ4MXZBLKH&cx=c&gtm=4e65d0"> (no integrity)
```

```
<script src="https://d2r1yp2w7bby2u.cloudfront.net/js/clevertap.min.js"> (no integrity) (and 37 more)
```

REMEDIATION

For each cross-origin `<script src="...">`, add `integrity="sha384-..."` and `crossorigin="anonymous"`.

Generate hashes via: `openssl dgst -sha384 -binary <file> | openssl base64 -A`

Prefer pinning a specific version of the asset so the hash stays stable.

INFO Missing Referrer-Policy header

P1-03

 Security Headers  HTTP response headers

Without a Referrer-Policy, the full URL of your pages (including any sensitive query parameters) is sent to third-party sites when users click external links.

IMPACT

Sensitive data in query parameters (user IDs, tokens, search terms) may leak to analytics or ad networks.

EVIDENCE

```
referrer-policy header not present
```

REMEDIATION

Add: Referrer-Policy: strict-origin-when-cross-origin

INFO Missing Permissions-Policy header

P1-03

 Security Headers  HTTP response headers

Permissions-Policy restricts which browser features (camera, microphone, geolocation) your site and embedded iframes can access. Without it, any third-party script could request access to these features.

IMPACT

Malicious or compromised third-party scripts could request sensitive device permissions.

EVIDENCE

```
permissions-policy header not present
```

REMEDIATION

Add: Permissions-Policy: camera=(), microphone=(), geolocation=()

Customize to allow only the features your app actually uses.

 Security Headers  HTTP response headers

COOP isolates your page from cross-origin windows opened via `window.open` or popups. Without it, a malicious site you opened a popup to can read state from your window via opener references, enabling cross-window data leaks (Spectre-class and tabnapping risks).

IMPACT

Cross-origin popups or openers can probe your page state. Cross-origin isolation features (SharedArrayBuffer, high-resolution timers) also require this header.

EVIDENCE

```
cross-origin-opener-policy header not present
```

REMEDIATION

Add: Cross-Origin-Opener-Policy: same-origin

Use same-origin-allow-popups if you need to keep references to popups you open.

 Security Headers  HTTP response headers

COEP requires every cross-origin resource you load to opt-in via CORP or CORS. Combined with COOP it enables cross-origin isolation, which is required by SharedArrayBuffer and high-resolution timers and which materially raises the bar for cross-process side-channel attacks.

IMPACT

Without COEP, cross-origin isolation is off and side-channel attacks across origins are easier to mount. Some advanced APIs (SharedArrayBuffer, `performance.measureUserAgentSpecificMemory`) are also unavailable.

EVIDENCE

```
cross-origin-embedder-policy header not present
```

REMEDIATION

Add: Cross-Origin-Embedder-Policy: require-corp

If third-party embeds break, try `credentialless` instead of `require-corp`.

 Third-Party Scripts  prod-assets.nike.in

Your site loads JavaScript from domains that are not in the list of commonly known, trusted providers. Unrecognized third-party scripts have full access to your page DOM, user keystrokes, and cookies.

IMPACT

A compromised or malicious third-party script can steal credentials, payment info, and session tokens from your users.

EVIDENCE

Scripts loaded from: prod-assets.nike.in

REMEDIATION

Identify each domain and verify it is intentionally included.

For unrecognized scripts, investigate the source and remove if not needed.

Add Subresource Integrity (SRI) hashes to all third-party script tags.

Consider hosting critical scripts yourself instead of loading from third-party CDNs.

AI DISCOVERABILITY · 1 ISSUE

 AI Discoverability  /llms.txt

llms.txt (llmstxt.org) is an emerging convention that gives AI assistants a curated, plain-Markdown map of your most important content. Without it, AI search tools fall back to guessing from your full HTML, which is noisier and may surface the wrong pages.

IMPACT

Reduced control over how AI assistants summarise and cite your site. This is an opportunity gap, not a defect — many sites do not yet ship llms.txt.

EVIDENCE

GET https://www.nike.in/llms.txt did not return a usable file

REMEDIATION

Add an /llms.txt file at the site root.

First line must be an H1 with the site/product name: "# Acme Docs".

Optionally add a blockquote summary, then "###" sections listing key pages as "[Title](https://...): short note".

Keep it curated — link the canonical, high-value pages only.

PRIVACY & COMPLIANCE · 5 ISSUES

 Privacy & Compliance  <https://www.nike.in/>

No "delete account" or "close account" control was detected in the page DOM. GDPR Arts. 17-18 grant users rights to erasure and restriction of processing; many privacy frameworks expect an accessible self-service path. This is a DOM observation — the control may be behind authentication or on a settings page not reached by the crawler.

IMPACT

Users may lack a convenient self-service path to exercise their privacy rights. Absent affordances can increase support burden and regulatory exposure.

EVIDENCE

Auth/account surface was detected (password input or auth link present). No matching control found in 136 scanned link/button text(s).

REMEDIATION

Add a clearly-labelled "Delete my account" button or link in the user settings or profile page.
Ensure the control is reachable without contacting support.
Link to the control from the privacy policy.

 Privacy & Compliance  <https://www.nike.in/>

No "download my data" or "export data" control was detected in the page DOM. GDPR Art. 20 (data portability) and CCPA §1798.100 give users rights to receive a copy of their personal data. This is a DOM observation — the control may be behind authentication or on a settings page not reached by the crawler.

IMPACT

Users may lack a convenient self-service path to exercise their privacy rights. Absent affordances can increase support burden and regulatory exposure.

EVIDENCE

Auth/account surface was detected (password input or auth link present). No matching control found in 136 scanned link/button text(s).

REMEDIATION

Add a "Download my data" button on the user account or settings page.
Generate a JSON or CSV export of the user's personal data when requested.
Document the export format and what data is included.

 Privacy & Compliance  <https://www.nike.in/>

No "Do Not Sell My Personal Information", "Your Privacy Choices", or "Do Not Share My Personal Information" link or button was detected. CCPA §1798.120 requires businesses that sell personal data to California residents to provide a prominent opt-out link. This is a DOM observation — if the site does not sell personal data, this affordance may not be required.

IMPACT

Users may lack a convenient self-service path to exercise their privacy rights. Absent affordances can increase support burden and regulatory exposure.

EVIDENCE

Auth/account surface was detected (password input or auth link present). No matching control found in 136 scanned link/button text(s).

REMEDIATION

If you sell or share personal data, add a "Do Not Sell or Share My Personal Information" link to the site footer.

Link to an opt-out mechanism or privacy preference centre.

Consult legal counsel to confirm whether CCPA obligations apply to your site.

 Privacy & Compliance  <https://www.nike.in/cp/privacy-policy>

A link matching common privacy policy text or URL patterns was found in the page HTML (footer). This is an observation only — the content or adequacy of the linked policy has not been evaluated.

IMPACT

None from this finding. Policy content quality is not assessed here.

EVIDENCE

Link text: "Nike Privacy Policy" | href: "https://www.nike.in/cp/privacy-policy" |
Placement: footer

 Privacy & Compliance

prod-assets.nike.in, nike.com, www.nike.com, images-static.nykaa.com, www.googletagmanager.com, , cdn.mxpnl.com, d2r1yp2w7bby2u.cloudfront.net, connect.facebook.net, 4171764.fls.doubleclick.net, www.google.com, googleads.g.doubleclick.net, analytics.google.com, stats.g.doubleclick.net, www.google.co.in, in1.clevertap-prod.com, mpc-prod-28-1053047382554.us-central1.run.app, www.facebook.com, mpc2-prod-24-is5qnl632q-uw.a.run.app, js-agent.newrelic.com, bam.nr-data.net, api-js.mixpanel.com

The page loads resources from or sets cookies on third-party domains. A privacy policy link was found on the page, which is a positive signal. This finding is informational — it lists the processors for awareness. GDPR and CCPA require that your privacy policy accurately describes each processor and the data it receives.

IMPACT

Low — a privacy policy link is present. Ensure the policy accurately describes each listed processor and the data they receive.

EVIDENCE

Third-party processors detected: prod-assets.nike.in, nike.com, www.nike.com, images-static.nykaa.com, Google Tag Manager (www.googletagmanager.com), , cdn.mxpnl.com, d2r1yp2w7bby2u.cloudfront.net, Facebook Pixel (connect.facebook.net), Google Ads (4171764.fls.doubleclick.net), www.google.com, Google Ads (googleads.g.doubleclick.net), Google Analytics (analytics.google.com), Google Ads (stats.g.doubleclick.net), www.google.co.in, in1.clevertap-prod.com, mpc-prod-28-1053047382554.us-central1.run.app, www.facebook.com, mpc2-prod-24-is5qnl632q-uw.a.run.app, js-agent.newrelic.com, bam.nr-data.net, Mixpanel (api-js.mixpanel.com).

A privacy-policy link was observed on the page.

REMEDIATION

Confirm that your privacy policy names each third-party processor listed above.
Verify that your cookie consent mechanism (if required) covers these processors.
Periodically audit third-party integrations and remove unused ones.

 Web-App Manifest Exposure  <https://www.nike.in/manifest.json>

Every time a user launches the installed PWA, the browser navigates to start_url. Tracking parameters there fire on every cold start — even offline — and may inflate analytics or violate user expectations.

IMPACT

No security impact. Privacy / analytics hygiene only.

EVIDENCE

```
start_url: /?utm_source=standalone&utm_medium=pwa · tracking params: utm_source,
utm_medium
```

REMEDIATION

Remove tracking parameters from start_url. If you need install attribution, use the manifest's `id` field or the `referrer` data the browser already exposes.

ACCESSIBILITY COMPLIANCE · 1 ISSUE

 Accessibility Compliance  <https://www.nike.in/>

This signal is derived from Lighthouse's automated accessibility checks, which cover a subset of WCAG 2.2 success criteria detectable by static analysis. It is NOT a full WCAG 2.2 AA audit and cannot be used as a compliance attestation. Relevant regulatory frameworks that reference WCAG 2.2 AA include the ADA (US), Section 508 (US federal), and EN 301 549 (EU) — conformance with these requires a comprehensive audit by a qualified assessor, not an automated scan.

IMPACT

A lower Lighthouse accessibility score suggests more potential barriers for users of assistive technology. It does not constitute a legal finding. Organisations subject to ADA, Section 508, or EN 301 549 should commission a qualified WCAG 2.2 AA audit independently of this scan.

EVIDENCE

```
Lighthouse accessibility subset score tier: high (≥90). Source: lab. No
accessibility statement link was detected on this page.
```

REMEDIATION

Review the detailed Lighthouse accessibility report for specific rule failures.
Use a screen reader (NVDA, VoiceOver, JAWS) to manually test key user flows.
Engage an accessibility specialist for a WCAG 2.2 AA conformance evaluation.
Consider publishing an accessibility statement describing known limitations and remediation plans.

05 What passed

Page 06

11 checks passed cleanly. Worth keeping a record so future regressions are easy to spot.

- ✓ **Exposed API keys & secrets**
Client-Side Secrets — no issues detected.
- ✓ **HTTPS / SSL setup**
TLS Configuration — no issues detected.
- ✓ **Cookie & session safety**
Cookie & Storage — no issues detected.
- ✓ **Cross-origin access rules**
CORS Configuration — no issues detected.
- ✓ **Insecure resource loading**
Mixed Content — no issues detected.
- ✓ **Dormant subdomain check**
Subdomain Takeover — no issues detected.
- ✓ **Leaky error messages**
Error Disclosure — no issues detected.
- ✓ **Exposed admin pages**
Admin Interfaces — no issues detected.
- ✓ **Search engine exposure**
robots.txt & Sitemap — no issues detected.
- ✓ **Cache leak check**
Cache Configuration — no issues detected.
- ✓ **Cookie consent banner check**
Cookie Consent — no issues detected.

06 Compliance signals

Page 07

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

GDPR

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

Not observed — Data-protection-relevant header not set: Content-Security-Policy

Not observed — Data-protection-relevant header not set: Referrer-Policy

Not observed — Data-protection-relevant header not set: Permissions-Policy

Not observed — Account-deletion affordance not observed in DOM

Not observed — Data-export/download affordance not observed in DOM

Not observed — "Do Not Sell / Share My Personal Information" affordance not observed in DOM

Observed — Privacy policy link observed

Observed — Third-party data processors observed (privacy policy link present)

CCPA

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

Not observed — Account-deletion affordance not observed in DOM

Not observed — Data-export/download affordance not observed in DOM

Not observed — "Do Not Sell / Share My Personal Information" affordance not observed in DOM

Observed — Privacy policy link observed

Observed — Third-party data processors observed (privacy policy link present)

WCAG / ACCESSIBILITY

⚠ Not legal advice. Not a compliance attestation. Signal detection only.

Observed — Lighthouse accessibility signal: high (≥ 90) score tier

07 Recommended next steps

Page 08

A pragmatic three-week plan. Each step is reversible and ships behind a feature flag where appropriate.

THIS WEEK

Patch the easy wins

Address the low-effort header and configuration fixes called out in the priority section. Typically a single deploy, **+5 to +10 points** on the security score.

NEXT SPRINT

Roll out defense-in-depth

Ship a report-only Content Security Policy, raise HSTS to a preload-ready max-age, and enable Subresource Integrity for third-party scripts.

WITHIN 30 DAYS

Run an active DAST scan

Passive scans can't verify exploitability. Verify your domain and run an active test to probe SQL injection, XSS, and API fuzzing on authenticated routes.

Want to compare this scan to your last one? Re-scan from your dashboard and select *Compare to previous*. VibeSafe will show which findings opened, closed, or changed severity since this report.

OUT OF SCOPE FOR A PASSIVE SCAN

Authenticated flows. Broken access control, IDOR, privileged endpoints — need a logged-in session to test.

Source-code findings. Hardcoded secrets in private repos, vulnerable dependency versions, SSRF gadgets — require code access.

Live exploit probes. Real SQL injection, XSS payloads, API fuzzing — require domain verification and explicit consent.

08 Glossary & references

CSP	Content Security Policy — an HTTP header that tells the browser which sources of scripts, styles, images, and connections are allowed. Mitigates XSS impact.
HSTS	HTTP Strict Transport Security — instructs browsers to refuse plaintext HTTP to your origin for a given duration. Preloading bakes this into the browser itself.
SRI	Subresource Integrity — a cryptographic hash on a <script> or <link> tag. The browser refuses to execute the resource if the bytes don't match.
SameSite	A cookie attribute (Strict, Lax, None) controlling whether the cookie is sent on cross-site requests. Mitigates CSRF.
LCP / INP / CLS	Core Web Vitals — Largest Contentful Paint (when the main content appears), Interaction to Next Paint (responsiveness), Cumulative Layout Shift (visual stability).
WCAG 2.2 AA	Web Content Accessibility Guidelines, level AA — the legal baseline for accessibility in the EU, UK, and most US public-sector procurement.
DAST	Dynamic Application Security Testing — probing a running application with real attack payloads, as opposed to static analysis of source code.
KEV / EPSS	CISA's Known Exploited Vulnerabilities catalog and FIRST's Exploit Prediction Scoring System — used to rank CVEs by real-world exploitation rather than CVSS alone.

REFERENCES

OWASP Secure Headers Project — owasp.org/www-project-secure-headers
Mozilla Observatory — observatory.mozilla.org
Google web.dev — web.dev/vitals
W3C WCAG 2.2 — w3.org/TR/WCAG22

09 Report attestation

This report was generated automatically by VibeSafe and is not a substitute for a manual penetration test. It is designed for triage, prioritization, and conversation — not certification.

Report ID	rpt_cmpayk59
Scan ID	cmpayk59t000rr9k8hxx0a1g9
Issued	May 18, 2026
Valid until	August 16, 2026 (or next deploy)
Scanner version	VibeSafe v0.4.2
Prepared for	rahulsunny13@gmail.com

ISSUED BY	REVIEWED BY
VibeSafe Automated Scanner vibesafe.app · contact@vibesafe.app	Name & date (optional human review)

How to read this report. Severity reflects exploitability and blast radius, not absolute risk. A high-severity finding on a low-traffic marketing page is less urgent than a medium on the login flow. Use the *Priority findings* section as your starting point — it's already ordered for you.

© 2026 VibeSafe. This report is confidential and intended for the named recipient only. Findings are based on the public response of nike.com at the time of scanning and may not reflect the current state of the site.